

MODULE 13 · DOMAIN 3 - AI SAFETY, SECURITY, AND GOVERNANCE

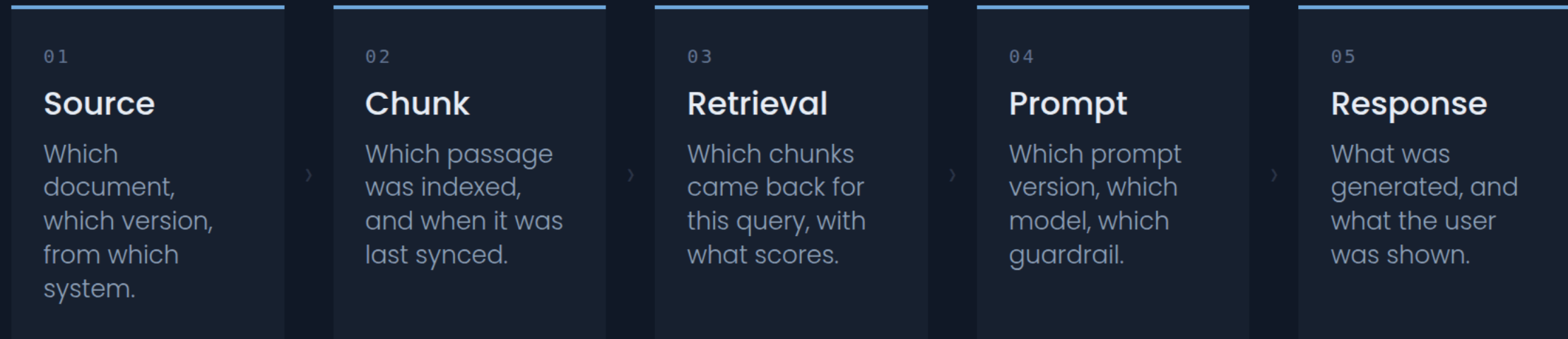
Governance and Responsible AI

Tasks 3.3 and 3.4. Audit trails, lineage, model cards, citations, bias, drift and human oversight.

DOMAIN 3 of 5 EXAM WEIGHT 20% MODULE 13 of 22

Governance is the ability to reconstruct **how a specific answer happened**. A generative AI system throws that information away by default, at every stage.

What traceability actually has to link



ON THE EXAM

Break any one link and the chain fails. The commonest break is between retrieval and response, because most systems never record which chunks fed a given answer.

Two audit systems, two different questions

	AWS CLOUDTRAIL	MODEL INVOCATION LOGGING
Answers	Who called what, when, from where	What was actually said
Captures	API calls and management actions	Prompts, completions, embeddings, images
Default	On for management events	Off. You enable it deliberately
Destination	CloudTrail, and optionally S3	S3, CloudWatch Logs, or both
Contains content?	No prompt or response text	Yes, which creates a privacy obligation

ON THE EXAM

Compliance questions usually need both. CloudTrail proves a call was made under a given identity; invocation logging proves what that call produced.

The four things the exam guide names

- ◆ **Programmatic model cards** in SageMaker AI: intended use, training data, evaluation results, known limitations.
- ◆ **AWS Glue for automatic data lineage.** Which source produced which dataset, tracked rather than documented.
- ◆ **Metadata tagging** for systematic data source attribution, which is module 4's metadata design seen from the compliance side.
- ◆ **CloudWatch Logs for decision logs.** Not just errors: a record of what the system decided and on what basis.
- ◆ Documentation written by hand drifts from reality. "Programmatic" and "automatic" are in the guide's wording for a reason.

ON THE EXAM

Notice how much of this is module 4 again. Metadata designed for retrieval precision turns out to be the same metadata an auditor needs for attribution.

Model cards or AI Service Cards?

SAGEMAKER MODEL CARDS

You create them

- One per model you build or customise
- Intended use, data, metrics, limitations
- Created programmatically in a pipeline
- Your internal governance artefact

AWS AI SERVICE CARDS

AWS publishes them

- Transparency documentation for AWS services
- Intended use cases, limitations, design choices
- You read them; you cannot author one
- Input to your own risk assessment

THE TIEBREAKER

"Document our own fine-tuned model for the regulator" is a model card. "Understand what AWS says about this managed service" is an AI Service Card.

A customer has complained about advice given nine months ago. A financial regulator has asked the lender to demonstrate three things. Exactly what the assistant said, which policy documents informed it, and which model and prompt version produced it.

The lender has CloudTrail enabled with a two-year retention, knowledge base sync logs, and application logs recording the user's question and a request ID. Model invocation logging was never enabled.

What can the lender demonstrate, and what should change?

- ☐ A Everything required. CloudTrail records the invocation, so the prompt and response can be recovered from it
- ☐ B Only that a call was made and by whom. Enable model invocation logging to S3, and record retrieved chunk identifiers alongside each response going forward
- ☐ C Everything required, by re-running the same question against the knowledge base today
- ☐ D Nothing useful. The only remedy is to retain full conversation transcripts in DynamoDB indefinitely

What can the lender demonstrate, and what should change?

A CloudTrail has it all

CloudTrail records that InvokeModel was called, by which principal, when. It does not contain the prompt or the completion.

C Re-run the question today

The documents, the index, the prompt version and possibly the model have all changed in nine months. You would be demonstrating today's system.

B Only the call itself. Enable invocation logging and record chunk IDs

Names honestly what is recoverable now, and fixes both broken links: content through invocation logging, and retrieval through recorded chunk identifiers.

D Nothing useful, retain everything forever

Over-corrects. Indefinite retention of conversation content creates a large privacy liability, and module 12 showed erasure then becomes far harder.

THE SIGNAL

The retrieval link is the one people miss. Even with invocation logging on, the prompt shows the chunks' text but not which document versions they came from unless you record the identifiers.

Data source tracking, end to end

- ◆ Register sources in the Glue Data Catalog, so what feeds the system is a maintained record rather than folklore.
- ◆ **Metadata tagging for source attribution in FM-generated content.** The tag rides with the chunk into the answer.
- ◆ **CloudTrail for audit logging** of who registered, changed or removed a source.
- ◆ Record **chunk identifiers and document versions** with each response. That is the retrieval link in the chain.
- ◆ A citation showing a document title is weaker than one showing a document *version*. Policies get revised.

ON THE EXAM

The exam guide's phrase is source attribution in FM-generated content. That means attribution surviving all the way into the answer, not just existing in a catalogue somewhere.

A citation is the cheapest transparency mechanism there is, and the most commonly skipped. It also happens to be **the strongest hallucination control** a user can operate themselves.

Three ways to make an FM output transparent

- ◆ **Reasoning displays** that give the user an explanation of how the answer was reached.
- ◆ **Confidence metrics collected in CloudWatch** to quantify uncertainty across the system, not just per answer.
- ◆ **Evidence presentation**: showing the source passage, not merely naming the document.
- ◆ **RetrieveAndGenerate returns citations automatically**, which is a real reason to prefer it over assembling prompts yourself.
- ◆ A reasoning display is a *narrative*, not a mechanism. It shows plausible reasoning, not necessarily the actual computation.

ON THE EXAM

That last point matters. A model asked to explain itself produces a convincing explanation whether or not it describes what happened. Citations are evidence; explanations are prose.

Citation or explanation?

CITATION

Evidence, verifiable

- Points at a passage that exists
- The user can check it themselves
- Survives audit years later
- Cheap, and mechanically produced

EXPLANATION

Narrative, plausible

- The model describes its reasoning
- Reads well and may be post hoc
- Cannot be independently verified
- Useful for users, weak for auditors

THE TIEBREAKER

"The regulator must be able to verify" means citations. "Users need to understand why" allows explanations. Only the first is evidence.

A medical information service answers clinician questions from a knowledge base of clinical guidelines. Clinicians have said they will not rely on answers they cannot verify against the guideline text, and the clinical safety officer requires that every answer be traceable to a specific guideline version.

The application currently uses the Retrieve API, assembles its own prompt, and returns a paragraph of prose. A developer has proposed appending a sentence asking the model to explain which guidelines it used.

What should the service implement?

- ☐ A Append the instruction asking the model to explain which guidelines it used
- ☐ B Switch to RetrieveAndGenerate for automatic citations, or continue with Retrieve while carrying the chunk's source document and version metadata into the response
- ☐ C Enable model invocation logging so the retrieved context is recorded for later inspection
- ☐ D Add a contextual grounding check so ungrounded answers are blocked

What should the service implement?

- A

 Ask the model to explain
Produces a plausible narrative that may be constructed after the fact. Clinicians asked to verify against the text, which prose about guidelines does not enable.
- B

 RetrieveAndGenerate citations, or carry the metadata through
Citations are mechanically derived from the chunks actually retrieved, and carrying document version satisfies the traceability requirement exactly.
- C

 Model invocation logging
Gives the safety officer an audit trail and gives the clinician nothing at the moment of reading. The requirement is verification at point of use.
- D

 Contextual grounding check
Genuinely valuable and complementary. It blocks ungrounded answers without letting a clinician see which guideline supports a grounded one.

THE SIGNAL

Two audiences with two requirements. The clinician needs verification at read time; the safety officer needs traceability afterwards. Citations carrying a version satisfy both at once.

Bias in a classifier is measurable: compare outcomes across groups. Bias in generated text is **diffuse**, appearing as tone, emphasis, assumption and what gets omitted.

Four places bias gets into a GenAI system

- ◆ **The base model.** Trained on a corpus you did not choose and cannot inspect.
- ◆ **Your retrieval corpus.** If the documents skew, the answers skew, and this one *is* yours to fix.
- ◆ **The prompt.** Wording, examples and role definitions all steer the model's assumptions.
- ◆ **Fine-tuning data.** A small dataset transmits its skew efficiently into behaviour.
- ◆ Only three of the four are under your control, and the retrieval corpus is the most tractable of them.

ON THE EXAM

Scenarios about skewed answers often point at the corpus rather than the model. If the knowledge base contains only documents from one region or one product line, that is where the skew is.

The responsible AI toolkit, and its status

SERVICE	WHAT IT DOES	STATUS
SageMaker Clarify	Bias metrics, feature attribution	Maintenance, Jun 2026
SageMaker Model Monitor	Data and model quality drift	Maintenance, Jun 2026
SageMaker Ground Truth	Human labelling for eval data	Maintenance, Jun 2026
Amazon Augmented AI	Managed human review workflows	Maintenance, Jun 2026
Bedrock Model Evaluation	LLM-native evaluation	Active. Module 16

ON THE EXAM

All four maintenance-mode services remain correct exam answers. Learn them as the answers, and know new work goes to Bedrock Model Evaluation.

Clarify was built for a different problem

- ◆ **Clarify's bias metrics assume structured data** and a defined outcome per group. Generated text has neither.
- ◆ **Feature attribution** explains which input features drove a prediction. A prompt is not a feature vector.
- ◆ It remains genuinely useful for the **classical ML components** around a GenAI system: routing, scoring, ranking.
- ◆ For generated text, the practical route is **LLM-as-a-judge evaluation over a stratified test set**.
- ◆ On the exam, Clarify is still the named answer for bias detection. Answer it, and know why it is awkward.

ON THE EXAM

This is a case where the honest engineering answer and the exam answer diverge slightly. Both are worth carrying, and the exam answer is the one that scores.

An insurer's assistant explains policy options to customers. An internal review found that answers to questions phrased in non-standard English were consistently shorter and omitted the optional cover explanations that other customers received.

The knowledge base contains the same documents for everyone and no metadata filter varies by customer. The team has proposed retraining the model on more diverse data.

What should the team do first?

- ☐ A Fine-tune the model on a more linguistically diverse dataset
- ☐ B Build a stratified evaluation set covering the affected phrasings, measure answer completeness against it, and investigate the prompt and retrieval behaviour before changing the model
- ☐ C Run SageMaker Clarify against the assistant's responses to compute bias metrics
- ☐ D Add an instruction to the prompt requiring answers of a minimum length

◆ PAUSE AND DECIDE

What should the team do first?

A Fine-tune on diverse data

The most expensive rung on module 2's ladder, chosen before anyone has established that the base model is the cause.

C Clarify on the responses

Bias metrics designed for structured outcomes across groups. There is no per-group outcome variable here, only prose of differing length.

B Stratified evaluation set, then investigate prompt and retrieval

Turns an anecdotal finding into a measurement, and checks the two components you control before rebuilding the one you do not.

D Minimum length instruction

Pads short answers to the required length without adding the omitted content. It hides the symptom and makes measurement harder.

THE SIGNAL

Retrieval is the likely culprit and the scenario hints at it: non-standard phrasing embeds differently, so it may simply be retrieving fewer relevant chunks. That is a module 5 problem.

Drift in a generative system

- ◆ **The corpus drifts.** New documents arrive, old ones are superseded, and retrieval quality moves with them.
- ◆ **The model drifts under you.** A provider updates a version, or your model reaches Legacy and you migrate.
- ◆ **Users drift.** People learn what the assistant is good at and ask different questions six months in.
- ◆ **The prompt drifts.** Small edits accumulate, and nobody re-runs the golden set for a wording tweak.
- ◆ Which is why the golden set is run **on a schedule**, not only on change. Nothing changed and the score moved is real.

ON THE EXAM

Traditional drift monitoring watches the input distribution. In a GenAI system the more dangerous drift is on the output side, and only periodic evaluation catches it.

Governance as an organisation, not a service

- ◆ Skill 3.3.3 asks for **frameworks aligned to organisational policy, regulation and responsible AI principles**. No service named.
- ◆ **The Well-Architected Generative AI Lens** from module 1 is the assessment instrument for this.
- ◆ **Service Catalog and IaC** turn an approved pattern into the path of least resistance for a team.
- ◆ **A review gate before production**, not before experimentation. Governance that blocks prototypes gets routed around.
- ◆ **An inventory of deployed FM applications** is the artefact most organisations lack and every auditor asks for.

ON THE EXAM

This is the one skill in the domain with no service attached. When a scenario describes teams doing the same thing differently, it is asking about consistency mechanisms.

Detecting and remediating policy violations

- ◆ **AWS Config** for resource-level compliance: is invocation logging on, is this guardrail attached, is this key a CMK?
- ◆ **CloudWatch alarms** on guardrail intervention counts, so a spike in blocked content is noticed rather than buried.
- ◆ **EventBridge** to route a finding into a remediation workflow or a ticket.
- ◆ **AWS Audit Manager** to collect evidence continuously against a control framework.
- ◆ Prefer **preventive** where you can, as module 12 argued. Automate detection for what prevention cannot reach.

ON THE EXAM

Config answers "is the control configured?" CloudWatch answers "is the control firing more than usual?" Both are detection, and both sit behind the preventive layer.

An organisation requires that every Bedrock knowledge base is encrypted with a customer managed key and that model invocation logging is enabled on every account. Both are documented in the AI standard.

A quarterly review found four knowledge bases created without a CMK and two accounts with logging disabled. All were created after the standard was published. The compliance team wants continuous assurance and automatic correction where possible, and a ticket raised where it is not.

What should the organisation implement?

- ☐ A AWS Config rules evaluating both requirements, with EventBridge routing non-compliant findings to an automatic remediation Lambda or a ticket where remediation is not possible
- ☐ B A monthly script that lists knowledge bases and accounts, and emails a report to the compliance team
- ☐ C An SCP denying creation of knowledge bases without a CMK
- ☐ D CloudTrail alerts on CreateKnowledgeBase API calls

What should the organisation implement?

- A

Config rules plus EventBridge remediation or ticket

Config evaluates continuously rather than quarterly, and the EventBridge split matches the stated requirement: remediate what can be fixed, raise a ticket for the rest.
- B

Monthly script and email report

Improves the cadence from quarterly to monthly and remains a manual report. Neither continuous nor automatic, which are both stated.
- C

SCP denying creation without a CMK

A strong preventive control, and it covers one of the two requirements. Logging enablement is an account setting, not a creation parameter.
- D

CloudTrail alerts on creation

Detects the event and not the compliance state. It also says nothing about resources that already exist non-compliant.

THE SIGNAL

Option C is genuinely better engineering for its half of the problem, and answers only half. When a scenario states two requirements, the option covering one of them is not the answer.

A local authority is deploying an assistant that helps caseworkers assess eligibility for housing support. The assistant retrieves policy and produces a recommendation. Caseworkers make the final decision.

The authority's counsel has asked what happens when a decision is challenged. The current design logs the caseworker's decision and the assistant's recommendation, but nothing about what informed the recommendation or whether the caseworker agreed with it.

What should the authority add?

- ☐ A Remove the recommendation entirely so the assistant only retrieves policy, avoiding the question
- ☐ B Record the retrieved chunks with document versions, the prompt and model version, the recommendation, whether the caseworker accepted or overrode it, and their stated reason
- ☐ C Enable model invocation logging and retain it for the statutory period
- ☐ D Add a disclaimer stating the recommendation is advisory and the caseworker is responsible

◆ PAUSE AND DECIDE

What should the authority add?

A Remove the recommendation

Avoids the governance question by deleting the feature. It is a legitimate option in some contexts and not what a challenge process needs.

C Invocation logging for the statutory period

Captures prompt and completion, which is one link. It records nothing about which policy version informed it or what the caseworker did with it.

B Record the full chain, including accept or override and the reason

Completes every link, and the accept-or-override record is what evidences meaningful human oversight rather than rubber-stamping.

D A disclaimer

Allocates responsibility on paper and produces no evidence. When a decision is challenged, a disclaimer answers none of the questions asked.

THE SIGNAL

The override record is the point. Human oversight is only meaningful if you can show humans sometimes disagreed, and a system with a 100% acceptance rate is not being overseen.

The whole domain on one slide

- ◆ **Guardrails** are six policy types, enforced by IAM, applicable to any model through ApplyGuardrail.
- ◆ **Hallucination is not content safety.** Ground it, check the grounding, constrain the shape, escalate.
- ◆ **Five control points**, and logging is not one of them. Choose the moment for PII, not the service.
- ◆ **Traceability links five things.** CloudTrail for the call, invocation logging for the content, citations for the source.
- ◆ **Prefer preventive.** Detection is what you automate for the things prevention cannot reach.

ON THE EXAM

That is 20% of the exam, and 77% now covered across three domains. Module 14 opens Domain 4 with cost and performance optimisation.